南京大學
NANJING UNIVERSITY

不同标准下 SBOM 文档的无损转换

学号：211250104　　答辩人：陈盛　　导师：周鑫

嚴謹求實
勤奮創新

南京大學
NANJING UNIVERSITY

目录
CONTENTS

项目背景

背景知识和技术基础

工具设计

工具验证

总结与展望

1 项目背景

项目背景

痛点

- 高度依赖第三方组件带来的风险
- 软件供应链透明度严重缺失
- 信息盲区引发供应链安全攻击
- 安全攻击导致重大经济与声誉损失

典型案例

- SolarWinds 事件
- MOVEit 事件
- 3CX 事件

系统功能

SBOM 的提出

- SBOM 能够记录软件组件的名称、版本、依赖关系以及许可证等信息，这为漏洞管理、合规审计和供应链追溯给予了基础的数据支撑。
- 不过，当下 SBOM 生态系统存在多标准且互操作性欠缺的情况，这严重限制了其效能发挥。

目标

- 设计并实现一个 SBOM 工具，创建映射，解决 SPDX 与 CycloneDX 标准下生成的 SBOM 互不兼容的问题，达成 SBOM 在不同标准间的低损或无损转换。考虑到转换时信息的完备问题，要结合大模型技术，用相关的信息提示大模型进行补充。另外，最终转换后的 SBOM 文档得输入到要读取 SBOM 的工具里，以检验其是否可用。

2 背景知识和技术基础

SPDX 标准

- SPDX （系统包数据交换，前身为软件包数据交换）是一种用于传达 SBOM （软件物料清单）数据的开放标准。它可用于传递与软件包、文件、代码片段（或这些元素的组合）相关的元数据。 SPDX 是美国联邦政府 2021 年 5 月网络安全行政命令中批准的两种全栈 SBOM 格式之一（另一种是 CycloneDX ）。此外， 2021 年 9 月， SPDX 作为 ISO/IEC 5962:2021 标准发布，成为国际认可的 SBOM 标准。这些因素，加上全球范围内 SBOM 采用率的上升，使 SPDX 成为帮助组织理解和管理其软件供应链的日益重要且有价值的工具。

SPDX v2.3 Document shall contain:	SPDX Document Creation Information
SPDX v2.3 Document may contain:	Package Information
	File Information
	Snippet Information
	Other Licensing Information Detected
	Relationships between SPDX Elements Information
	Annotations Information
	Review Information

CycloneDX 标准

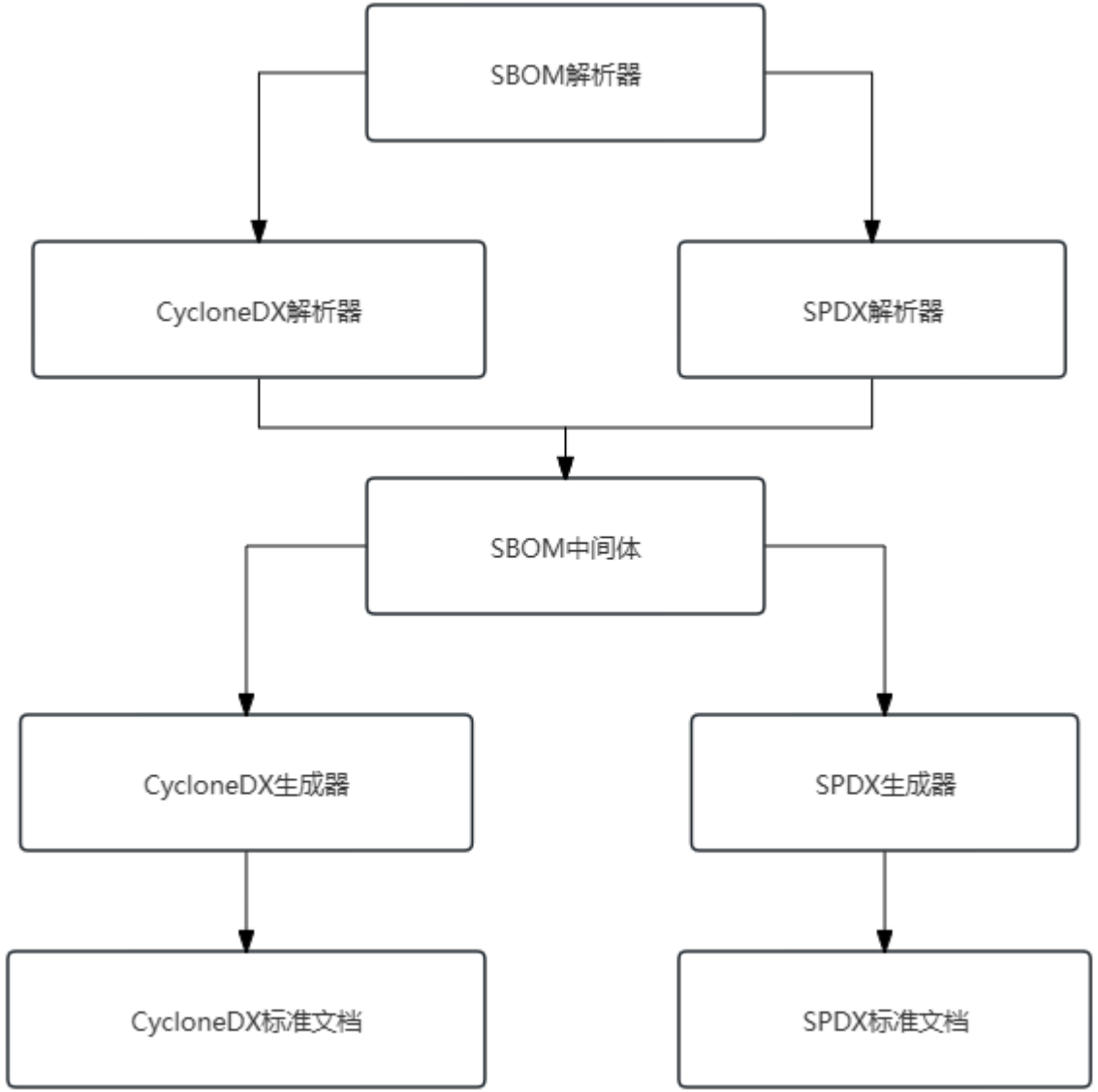
- CycloneDx 是一种为现代软件供应链设计的全栈物料清单规范。它作为软件物料清单（SBOM）标准最为人熟知 —— 且 SBOM 是其首要用例 —— 但 CycloneDx 也可用于漏洞报告和许多其他物料清单类型。自被列入美国联邦政府 2021 年网络安全行政命令中经批准的 SBOM 数据格式以来，CycloneDx 大受欢迎且被更多采用。该标准已存在数年，其历史可追溯至 2017 年初始原型发布之时。

模块名称	核心描述
BOM 元数据（BOM Metadata）	包含 BOM 描述的供应商、制造商、目标组件信息，以及 BOM 生成工具和文档自身的许可证信息，确保文档完整性与可追溯性。
组件（Components）	描述第一方和第三方组件的完整清单，支持软件、硬件、机器学习模型、源代码和配置等类型，包含制造商信息、许可证、版权细节及组件来源追溯。
服务（Services）	表示软件调用的外部 API，描述端点 URI、认证要求、信任边界跨越，支持数据流动描述（数据分类、流向），识别第三方服务风险。
依赖关系（Dependencies）	构建组件间依赖图，支持直接与传递依赖关系，可表示组件对服务的依赖及服务间依赖，便于漏洞传播路径分析。
组合（Compositions）	描述组成部分（组件、服务、依赖关系）及其完整性，完整性状态包括完整、不完整（分第一方/第三方）或未知，用于合规性校验。
漏洞（Vulnerabilities）	关联第三方和开源软件的已知漏洞及可利用性，支持披露未知漏洞，适配漏洞披露（VDR）和可利用性交换（VEX）场景。
注释（Annotations）	包含注释、说明等文本内容，提供对象附加上下文，支持工具自动生成或人工审核，可独立进行数字签名验证。
扩展（Extensions）	在对象模型中设置多个扩展点，支持新功能快速原型开发及行业特定场景，鼓励社区参与定制化扩展开发。

表 2-1 CycloneDX 标准部分核心模块结构

3 工具设计

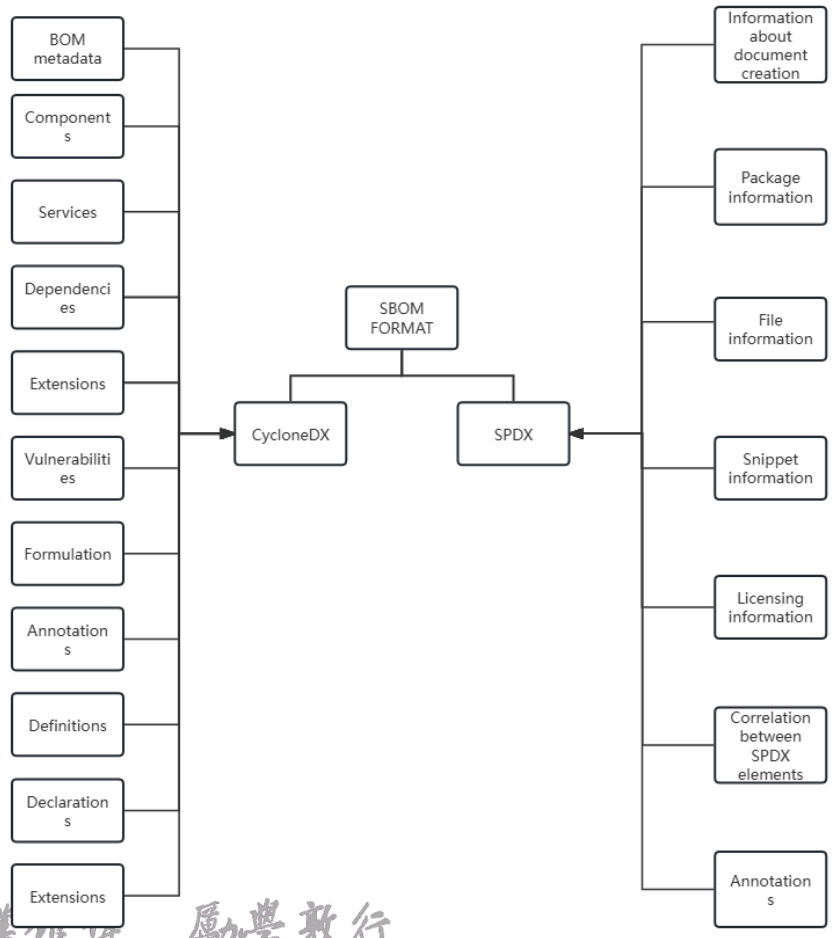
整体设计



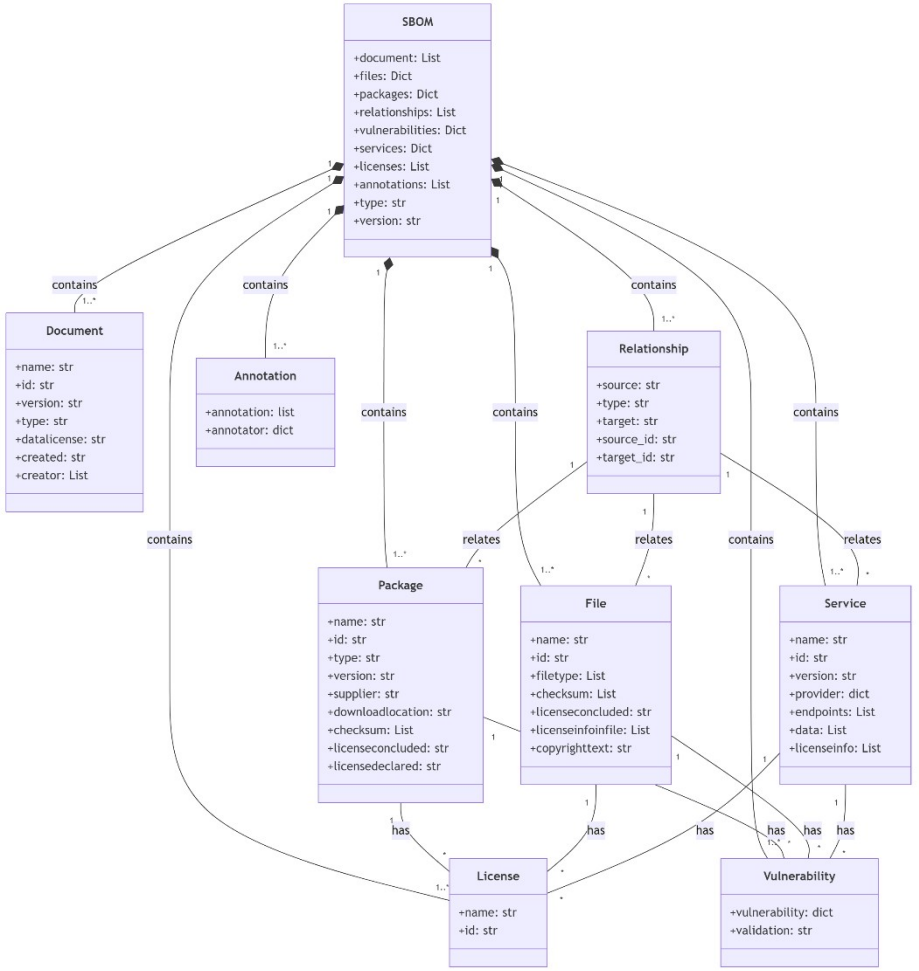
SBOM 中间体作为统一中间数据模型，通过 CycloneDX 解析器和 SPDX 解析器将两种格式文档转换为中间体，再借助 CycloneDX 生成器和 SPDX 生成器从中间体生成对应标准文档，实现 SPDX 与 CycloneDX 标准下文档的双向转换。

详细设计—— SBOM 中间体

俩种标准核心元素对比

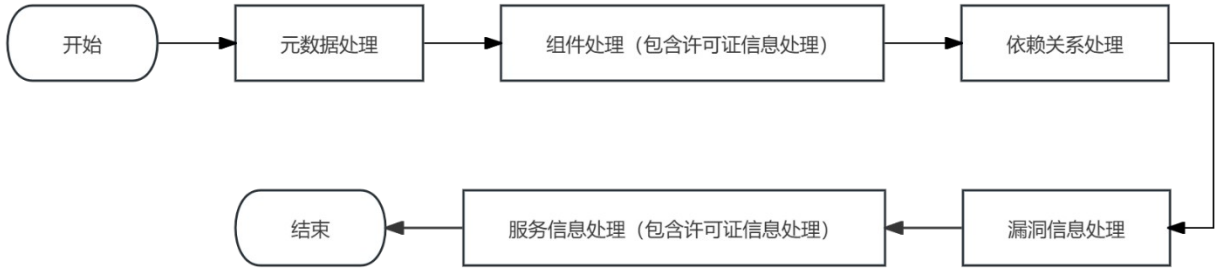


SBOM 中间体类图结构



详细设计——俩个解析器

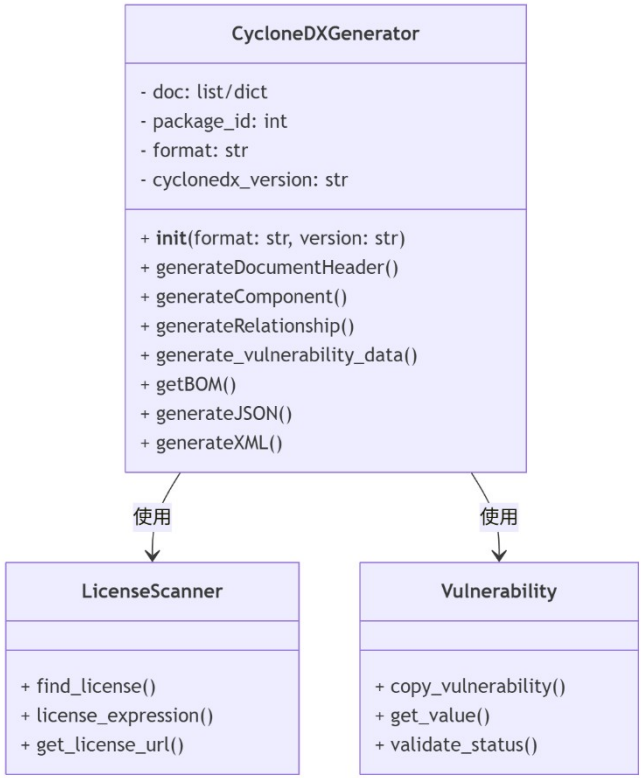
- CycloneDX 解析器进入漏洞信息处理阶段后，会系统地识别、提取并结构化 SBOM 中的安全漏洞数据。它把非规范化的漏洞描述转化为标准化的对象模型，给后续的安全分析与响应提供基础支持。



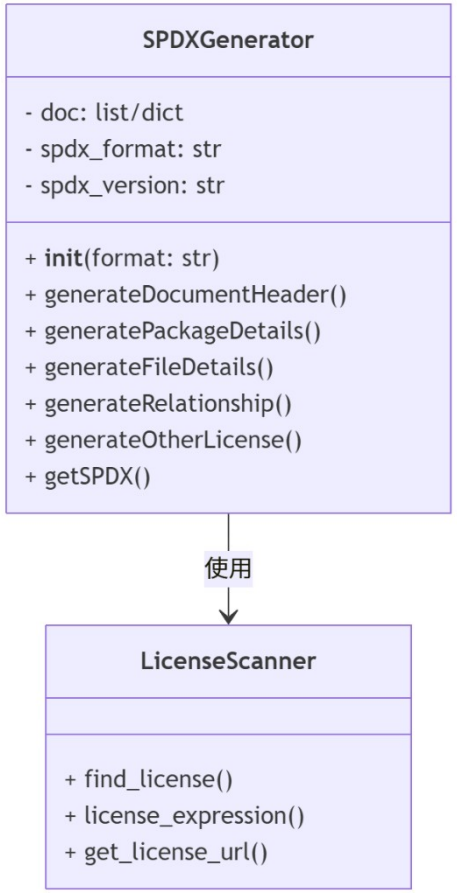
- SPDX 解析器的解析流程，是要把符合 SPDX 标准的 SBOM 文件，转换成结构化的 SBOM 中间体。其核心逻辑就是围绕文档、文件、包、依赖关系还有许可证这些核心元素。

详细设计——俩个生成器

- CycloneDX 生成器从 SBOM 中间体生成标准文档的过程就是通过模块化设计将内部数据结构按 CycloneDX 规范逐层组装。



- SPDX 生成器通过模块化的处理流程将 SBOM 中间体转换为符合 SPDX 规范的标准文档，支持 Tag/Value 和 JSON 两种格式输出。



详细设计——大模型增强转换

南京大學 NANJING UNIVERSITY

增强转换提示词示例

```
prompt = f"""
    分析以下CycloneDX许可证信息:
    - 许可证ID: {license_id}
    - 许可证名称: {license_name}

    请提供:
    1. 许可证关键条款摘要
    2. 主要合规义务
    3. 许可证兼容性指南
    4. 特殊注意事项
    """

    try:
        response = client.chat.completions.create(
            model="doubao-1-5-thinking-pro-******",
            messages=[
                {"role": "system", "content": "你是一个专业的
                   CycloneDX许可证分析专家。"},
                {"role": "user", "content": prompt}
            ]
        )

        analysis = response.choices[0].message.content.strip()

        # 在CycloneDX格式中添加属性
        license_obj["license"].setdefault("properties", [])
        license_obj["license"]["properties"].append({
            "name": "ark:license_analysis",
            "value": analysis
        })
```

4 转换工具实用性验证

系统实现——配置规则集合模块

南京大學 NANJING UNIVERSITY

- 使用 CycloneDX-cli 生成的 SPDX 文档在验证中暴露出三重结构性错误。

```
This SPDX Document is not valid due to:
        Invalid date format 2025-05-10T03:01:17.5817741Z.  Does not match the pattern ^\d{4}-\d{2}-\d{2}T\d{2}:\d{2}:\d{
2}Z$.
        Document must have at least one relationship of type DOCUMENT_DESCRIBES or contain only a single SpdxPackage
        Document namespace http://spdx.org/spdxdocs/cyclonedx cyclonedx-php-composer-demo-dev-master-223cb8bf-084d-4164-
a9f5-6e1d8851cf66 is not a valid URI
```

- 自主开发工具生成的 SPDX 文档仅触发一项验证错误。

```
This SPDX Document is not valid due to:
        Document must have at least one relationship of type DOCUMENT_DESCRIBES or contain only a single SpdxPackage
```

5 总结与展望

总结与展望

南京大學 NANJING UNIVERSITY

总结

在软件供应链安全威胁日益复杂的背景下，SPDX 与 CycloneDX 作为当前主流的 SBOM 标准，为组件管理、依赖追溯和许可证合规提供了重要支撑，但二者在数据结构、字段定义及语义表达上的差异，使得跨标准转换面临诸多挑战。当前市场对高效互操作工具的需求虽已显现，但相关研究仍处于探索阶段，现有方案在系统性整合异构标准差异方面尚存在较大提升空间。针对这一问题，本文尝试构建了一套 SPDX 与 CycloneDX 标准文档转换的分层架构，通过解析器、中间体、生成器的协同设计，初步实现了两种标准间的核心信息转换。研究聚焦于通过“SBOM 中间体”这一中间数据模型，将 SPDX 的 CreationInfo 与 CycloneDX 的 metadata、组件依赖关系、许可证体系等进行标准化抽象，试图在文档解析、数据整合与目标生成之间搭建桥梁。

总结与展望

展望

展望未来，我认为该领域可从以下方向开展进一步研究：首先，需深化对 SBOM 标准核心要素的对比分析，持续完善中间体模型，逐步覆盖更多字段与复杂场景，提升转换的准确性与完整性；其次，应加强与行业实践的结合，通过实测反馈优化解析与生成算法，探索与主流安全工具（如 SCA 工具、漏洞数据库）的集成路径，提升技术方案的实用性。

南京大學

NANJING UNIVERSITY

敬请老师批评指正！

学号： 211250104　　答辩人：陈盛　　导师：周鑫教授